

AT 4 Piloter un projet d'application sécurisée

Sujet 2 : Remise en conformité de l'application libXYZ - LOAN

Règlementation :

Etude de cas faisant l'objet d'une présentation orale (C18 à C24)

L'étude de cas porte sur les tests lors de la finalisation d'un projet d'évolution d'application (nouvelles fonctionnalités) avant son déploiement, sur la base de programmes informatiques développés. Les candidats travaillent en groupe et ont 4 heures pour produire un compte rendu écrit, sous forme de présentation PDF et/ou Powerpoint.

Lors de la soutenance orale (20 minutes de présentation + 10 minutes de questions/réponses), chaque candidat devra prendre la parole et se verra attribuer une note individuelle.

Contexte :

La librairie "XYZ", existant depuis 10 ans, a identifié la nécessité de se moderniser en vue d'une meilleure gestion de ses utilisateurs et de son inventaire de livres. Cette modernisation est envisagée par le développement d'une application web. En conséquence, la librairie XYZ a constitué un pôle IT composé de votre équipe remplaçant une précédente équipe de développement.

Une **première version a été fournie** par la précédente équipe de développement afin d'avoir une plateforme rapidement. Bien que fonctionnelle, elle possède de nombreuses failles de sécurité, en plus d'être peu optimisée et peu pertinente en cas d'évolution des besoins.

Pour l'avancée de cette solution, votre équipe utilisera la **méthodologie Agile**.

Pour cette mission, il vous est demandé de concentrer vos efforts sur la partie réservation de livre et l'application en général. Vous devrez donc les prioriser.

Les fichiers concernés sur la partie développements seront la configuration, l'index et la page d'accueil, le footer et les pages relatives à l'emprunt (nommée LOAN)

Lien du repository contenant le code :

<https://github.com/EduJALM/BC4SJ2-PYTHON.git>

Consignes :

Afin de préparer l'application à un déploiement sécurisé et efficace, vous réaliserez (en équipe) un rapport sous forme de fichier PPT et/ou PDF (qui vous servira de support de présentation orale) et dont voici le plan :

Répartition des tâches et fonctionnement Agile :

- **Détaillez la répartition des tâches au sein de votre équipe**, en expliquant le rôle de chaque membre dans le projet.
- Présentez un **fonctionnement Agile pour votre équipe**, en incluant les **méthodes de travail** que vous adopterez.

Revue de code mutuelle et déploiement sur un environnement de tests :

- Effectuez une **revue du code actuel**. Présentez **les résultats, les améliorations à apporter et les bonnes pratiques identifiées et/ou à apporter**.

Rapport de vulnérabilité :

- Utilisez **SonarQube** pour mener des **tests automatiques de qualité et vulnérabilités**. Présentez une **synthèse interprétée** des résultats obtenus.
- Menez des **tests statiques et/ou dynamiques** (limites et hors limites, injection, pentest).
- **Analysez les rapports des tests et présentez les attaques auxquelles l'application résiste**.
- Présentez une **synthèse des failles détectées**, leur **scoring**, et les **risques associés**.

Reformulation des spécifications et planification:

- Reformulez les spécifications fonctionnelles et techniques des composants testés, en tenant compte des failles identifiées.
- Proposez un planning Agile, présentant les correctifs à mettre en œuvre obligatoirement avant le déploiement final de l'application.

IMPORTANT :

- Veillez à renommer vos travaux avec vos nom et prénom.
- Les fichiers ne pourront pas être déposés sur la plateforme après le temps imparti.

Informations pratique :

Utilisateur Site Web :

Email utilisateur site web avec emprunt :

marc@lord.com

Mot de passe utilisateur avec emprunt :

gzafnezf@@15ezf

Email utilisateur site web sans emprunt :

ErwinSmith@wof.com

Mot de passe utilisateur sans emprunt :

gNfezjozalp!@545efzze

Administrateur Site Web :

Email administrateur site web :

john@smith.com

Mot de passe administrateur site web :

EFEZF451q5sdqs1d21z8

Déploiement actuel :

MySQL v8.0.36

Python v.3.12

Environnement de travail :

Vous pourrez réaliser les actions de votre choix, cela ne doit cependant pas faire tomber votre serveur de test.

L'instance est un Ubuntu server allégé tournant au sein d'un **container Docker**.

Un serveur sera attribué par groupement d'équipe.

Configuration installée :

NodeJS

nodeJS v20.11.1

npm v10.2.4

Python

Python 3.10.12

pip3 22.0.2

Django 5.0.3

PHP

PHP 8.1.2-1ubuntu2.14

Zend Engine v4.1.2

Composer v2.7.1

Symfony CLI v5.8.11

DataBase

MySQL v8.0.36-0ubuntu0.22.04.1

Serveur

Apache v2.4.52

Vos accès à la version déployée :

Groupe 1 à 4		https://exam-red.edu-jalm.fr
Groupe 5 à 8		https://exam-green.edu-jalm.fr
Groupe 9 à 12		https://exam-blue.edu-jalm.fr
Groupe 13 à 16		https://exam-yellow.edu-jalm.fr
Groupe 17 à 20		https://exam-silver.edu-jalm.fr
Groupe 21 à 24		https://exam-emeraud.edu-jalm.fr